

Atbalsts platformas drošības gatavība

Vadības kopsavilkums krīzes centra vadībai

Secinājums Platformu var droši demonstrēt, ja tā ir skaidri marķēta kā demonstrācijas vide. Apstiprinātais laidziens, minimāla publiskā diagnostika, piekļuves kontrole, procesu atjaunošanās un atgriešanās uz iepriekšējo versiju ir pārbaudīta. Reālai krīzes vadībai vēl jāievieš individuāli lietotāju konti, perimetra aizsardzība, darbības nepārtrauktība un obligātas cilvēku drošības pārbaudes.

93% Demonstrācijas gatavība

Augsta. Būtiskākie demonstrācijas kontroles punkti ir praktiski pārbaudīti; ārējie administratoru darbi ir atklāti norādīti.

66% Eksploatācijas drošības gatavība

Vidēja. Atlikušie 34 procentpunkti un to ieviešanas plāns izskaidrots otrajā lapā; tas nav audits vai sertifikācija.

Ko var droši parādīt šodien

✓ Kontrolēts laidziens

PR #73 apvienots pēc sekmīgas CI pārbaudes; publiski darbojas tieši apstiprinātais main komits 664b5e5.

✓ Pārbaudīta atkopšana

Lietotne un tunelis atjaunojas pēc procesa kļūmes; praktiski izmēģināta atgriešanās uz iepriekšējo versiju.

✓ Minimāla publiskā virsma

/api/health atklāj tikai stāvokli un laidiena SHA; publiskais notikumu API neizdod iekšējos laukus.

✓ Aizsargāta operatīvā piekļuve

Centra diagnostika un datu atsveidzināšana anonīmam lietotājam nav pieejama. MI nepublicē un nenosūta cilvēkus patstāvīgi.

Pašreizējā aizsardzības arhitektūra

Publiskais lietotājs → Cloudflare → drošs tunelis → Atbalsts lietotne → dati un MI pakalpojumi

Cloudflare samazina tiešu servera ekspozīciju, taču pašreiz ir viena lokāla izcelsmes instance. Cloudflare Worker pašlaik neapkalpo publisko domēnu, un Vite priekšskatījuma serveris ir pieļaujams tikai demonstrācijai.

Galvenie uzbrukuma ceļi

PROGRAMMATŪRA

API datu izguve, pieprasījumu plūdi un izmaksu palielināšana, sesiju zādzība, promptu injekcija, ļaunprātīgi faili un piegādes ķēdes kompromitēšana.

CILVĒKI UN PROCESS

Pikšķerēšana, kopīgi piekļuves dati, uzdošanās par partneri, kļūdaina publicēšana, iekšēja ļaunprātīga rīcība, nogurums un nepārbaudīta atkopšanas kārtība.

Ieviešanas robežas

01 Demonstrācija

VAR IZMANTOT TAGAD

Sintētiski dati, publiskā informācija, tikai lasāma karte un Centra skats. Kopīgā parole jānosauca kā apzināts demonstrācijas ierobežojums.

02 Kontrolēts pilots

AR NOSACĪJUMIEM

Pirms personas datu pilotprojekta vajadzīgi individuāli konti, MFA, novērtējums par ietekmi uz datu aizsardzību, glabāšanas noteikumi, failu karantīna un perimetra kontroles.

03 Operatīva lietošana krīzē

VĒL NEATĻAUT

Nepieciešama augsta pieejamība, brīdinājumi, incidentu un rezerves kopiju mācības, kā arī obligātas misiju kompetences, riska, piekrišanas un četru acu pārbaudes.

Produktu nošķiršana

Sākt ar publisko informāciju un tikai lasāmu karti. Tas ir drošākais atsevišķais produkts. Iedzīvotāju ziņojumus var pievienot kontrolētā pilotā pēc datu, failu un perimetra prasību izpildes.

Saglabāt izolētus vadības un nosūtīšanas moduļus.

Vadības centrs paliek demonstrācijas režīmā, bet misijas un brīvprātīgo nosūtīšanu nepalaiž līdz obligāto drošības pārbažu ieviešanai. MI paliek tikai padomdevēja lomā.

Ieviestās prakses un atlikušais darbs

Ekspluatācijas drošības gatavība ir 66%. Atlikušie 34 procentpunkti nav ievainojamību īpatsvars; tie apzīmē vēl neieviestās kontroles šajā iekšējā novērtējumā. Tās zemāk sasaistītas ar konkrētiem īpašniekiem un termiņiem.

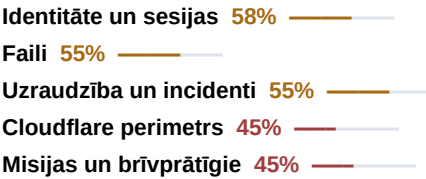
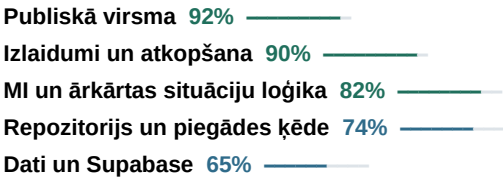
JAU IEVIESTĀS LABĀS PRAKSES

- ✓ **Kontrolēti laidieni un atkopšana**
PR apvienošana pēc CI, precīzs laidiena SHA, nemaināmas versijas, automātiska procesu atjaunošanās un praktiski pārbaudīta atgriešanās.
- ✓ **Minimāla publiskā datu virsma**
Veselības pārbaude izdod tikai statusu un SHA, atbildes netiek kešotas, bet publiskajā notikumu API izmantots atļauto lauku saraksts.
- ✓ **Piekļuves un ļaunprātīgas izmantošanas ierobežošana**
Aizsargātie maršruti anonīmam lietotājam dod 401; darbojas droši sīkfaili, izcelsmes pārbaudes un lietotnes pieprasījumu ierobežojumi.
- ✓ **Droša izstrāde dati un faili**
CI izpilda 32 pārbaudes un kritisku atkarību kontroli. Servera atslēgas nav klientā; ievades validē, bet failus glabā privāti un pārbauda to īpašnieku, tipu un izmēru.
- ✓ **Cilvēka kontrole pār MI**
Ārkārtas informācija tiek apstrādāta pirms MI. Publicēšanu un cilvēku nosūtīšanu apstiprina cilvēks; MI atbildes ierobežo shēmas un avoti.

PLĀNOTĀS KONTROLES ATLIKUŠAJIEM 34%

- **Individuāla identitāte un atbildība**
Ieviest individuālus kontus, MFA, sesiju atsaukšanu, ierīču pārvaldību un iespēju noteikt, kurš operators veicis katru darbību.
- **Perimetrs un repozitorija aizsardzība**
Ieviest Cloudflare WAF un ātruma ierobežojumus, pārskatīt Security Events un aizsargāt main ar obligātu PR, CI un CODEOWNERS apstiprinājumu.
- **Datu un failu pilns dzīves cikls**
Pabeigt datu karti, NIDA, glabāšanas un dzēšanas noteikumus, minimālās datubāzes lomas, failu karantīnu un ļaunprogrammatūras skenēšanu.
- **Noturīga ekspluatācija un incidentu vadība**
Aizstāt demonstrācijas serveri, pārbaudīt otru izcelsmes instanci, ieviest brīdinājumus, incidentu plānu un rezerves kopiju atjaunošanas mācības.
- **Misiju un brīvprātīgo drošība**
Ieviest kompetences, riska un piekrišanas pārbaudes, četru acu principu un MI pretnieka scenāriju pārbaudes.

Gatavība pa kontroles jomām



Četras nākamās prioritātes

01 Perimetrs un koda pārvaldība

Cloudflare un GitHub administratori · 17.09.2026
Ieviest perimetra noteikumus un galvenā zara aizsardzību.

02 Identitāte dati un faili

Produkta privātuma un drošības īpašnieki · Pirms personas datu pilota
Ieviest kontus, MFA, NIDA, datu dzīves ciklu un failu karantīnu.

03 Darbības nepārtrauktība

Infrastrukturā īpašnieks · 10.10.2026
Ieviest atbalstītu izpildvidi, otru instanci, brīdinājumus un atkopšanas mācības.

04 Cilvēku un misiju drošība

Produkta un operāciju vadība · Pirms reālu misiju palaišanas
Ieviest obligātās misiju drošības pārbaudes un saglabāt MI padomdevēja lomā.

Atbilstības ceļš

Obligātā piemērojamība Personas datiem piemēro VDAR. Atsevišķi jānosaka Nacionālā kiberdrošības likuma, NIS2 un MK noteikumu Nr. 397 piemērojamība, Kiberneturības akta prasības katram tirgū laistam produktam ar digitāliem elementiem un MI akta prasības pēc MI faktiskās lomas.

Ieviešanas ietvars NIST CSF 2.0 organizācijas risku pārvaldībai un OWASP ASVS 5.0 lietotnes kontrolēm. ISO/IEC 27001 sertifikāciju apsvērt, ja to prasa iepirkums vai tirgus.

Primārie avoti [VDAR](#) · [Nacionālās kiberdrošības likums](#) · [MK Nr. 397](#) · [Kiberneturības akts](#) · [MI akts](#) · [NIST CSF 2.0](#) · [OWASP ASVS 5.0](#)

Ieteicamais sapulces lēmums

Apstiprināt demonstrāciju pašreizējā vidē ar skaidri nosauktiem ierobežojumiem un sintētiskiem datiem. **Kontrolētu personas datu pilotu sākt tikai pēc 1. un 2. lēmuma izpildes. Reālu krīzes operāciju un cilvēku nosūtīšanu atļaut tikai pēc 3. un 4. lēmuma izpildes un praktiskām incidentu mācībām.**